SOC 網路攻擊偵測與 Log 分析模擬系統

軟體規格書

版本： 1.0
日期： 2026 年 10 月 10 日
交付形式： 單一 index.html 檔案

1. 專案目標與範圍

本系統是供作品集展示的互動式 SOC（Security Operations Center）分析工作台。使用者可透過四個內建事件，體驗檢視告警、搜尋 Log、建立事件時間線、辨識證據、評估風險及選擇處置策略的工作流程；也可在探索分析台自由檢視範例或自行提供的 Log。

系統須完全離線運作。所有 HTML、CSS、JavaScript、模擬資料及以 Canvas 或 SVG 繪製的圖表，均包含於同一個 index.html。不使用外部 CDN、API 或後端服務。系統定位為**分析流程模擬器**，不連接真實設備，也不執行封鎖或隔離操作。

2. 系統架構與頁面佈局

2.1 架構

系統由四個在瀏覽器內執行的部分組成：

1. **資料層：** 保存四個內建案例、標準答案、處置選項，以及使用者當次載入的 Log。
2. **解析與分析層：** 將 JSON 或純文字 Log 轉為統一欄位，提供搜尋、篩選、排序及事件關聯顯示。
3. **互動與評分層：** 管理任務進度、證據選取、風險判定、處置選擇及確定性評分。
4. **呈現層：** 顯示 SOC 儀表板、Log 表格、時間線、圖表及結果解析。

內建關卡進度與手動標記可儲存在瀏覽器的 localStorage，並提供重設功能。使用者上傳或貼上的原始 Log 僅供當次頁面使用，不寫入 localStorage。

2.2 三欄式 SOC 佈局

區域	主要內容	建議桌面寬度
左欄：導航與事件	模式切換、四個內建案例、告警清單、案例進度	約 240 px
中欄：分析工作區	概況圖表、搜尋與篩選列、Log 表格、事件時間線、原始紀錄	自適應剩餘寬度
右欄：調查面板	已選證據、風險等級、處置選項、提交按鈕、評分與解析	約 320 px

頁面頂部顯示系統名稱、目前案例或資料集、模式、事件數與高風險告警數。視覺採深藍、灰白的企業級 SaaS 風格，以有限的橘色與紅色標示警示及嚴重風險。色彩之外，風險也須有文字標籤。

桌面畫面優先；較窄的畫面可收合左欄，並將右欄改為可展開面板。搜尋、證據選取與提交操作須支援鍵盤使用。

3. 核心功能模組

3.1 調查闖關模式

系統提供四個可獨立完成的內建案例。每個案例包含背景簡述、混有正常紀錄的模擬 Log、三項標準證據、正確風險等級、兩項正確處置，以及提交後的解析。

使用流程如下：

1. 選擇案例並閱讀告警摘要。
2. 利用搜尋、篩選、圖表和時間線檢視 Log。
3. 點選 Log 列或其關鍵欄位，將最多三筆紀錄加入「調查證據」。
4. 選擇一個風險等級及最多兩項處置。
5. 提交答案，查看分數、正確證據、判定理由和處置解析。
6. 可重新嘗試；案例進度記錄最高分。

提交前不顯示標準答案。重新嘗試時清除當次選擇，但保留該案例的歷史最高分。

3.2 探索分析台

探索模式可檢視四個內建案例的 Log，或切換至使用者載入的資料。功能包括：

- 依時間、資料來源、IP、主機、使用者、事件類型及風險標記篩選。
- 以關鍵字搜尋解析欄位及原始 Log；依時間排序。
- 顯示事件數量趨勢、來源分布與風險分布圖表。
- 展開單筆 Log 查看完整欄位與原始文字。
- 對紀錄手動標記低、中、高或重大風險，並加入調查筆記。

探索模式不提供標準答案或自動評分。使用者的手動風險標記不改寫原始 Log。

3.3 Log 解析器

支援貼上內容，或從本機選取 .txt、.log、.json 檔案。輸入格式如下：

- **JSON：** 單一物件、物件陣列，或每行一個 JSON 物件。
- **純文字：** 每行視為一筆紀錄；嘗試擷取時間、IP、主機、使用者、HTTP 方法與狀態碼等可辨識欄位。

解析器須顯示成功筆數、未解析筆數及缺少的欄位。無法辨識的紀錄仍保留原始文字供搜尋，不自行推測缺失的時間或身分。對沒有時區的時間字串，保留原值並標示時區不明。

為維持單檔頁面的可用性，第一版以 **5 MB 或 10,000 筆紀錄**為載入上限，超過時清楚提示。所有外來 Log 都以純文字顯示，不作為 HTML 或程式執行。

4. 內建案例與判定依據

四個案例均包含正常流量與干擾紀錄，要求使用者根據**多筆紀錄的關聯**判斷，而非只看單一關鍵字。下表門檻僅定義內建情境。

案例	模擬攻擊特徵與三項標準證據	正確風	正確處置

		險	
SSH 暴力破解	同一外部 IP 對同一帳號在 5 分鐘內產生至少 25 次失敗登入；隨後 2 分鐘內從該 IP 登入成功；成功後出現異常的提權或管理操作。	高	封鎖來源 IP；停用或重設受影響帳號的憑證並檢查登入活動。
SQL Injection	同一來源在 2 分鐘內連續提交帶有 SQL 注入特徵的 Web 請求；其中請求觸發資料庫錯誤或異常回應；後續出現與平常差異明顯的成功回應或資料讀取跡象。單有攻擊字串不視為入侵成功。	高	封鎖或限制惡意請求來源；調查受影響端點與資料存取紀錄，並修補漏洞。
勒索軟體橫向移動	帳號對另一內部主機發起異常遠端登入；該主機出現可疑父子行程關係及 PowerShell 執行；短時間內至少 120 個檔案遭大量改寫或副檔名變更。	重大	隔離受影響主機；停用受影響帳號並保全調查證據。
異常資料外洩	內部主機先建立異常的大型封存檔；接著於 10 分鐘內向新出現的外部目的端傳送至少 2 GB；連線使用該主機平常少見的目的端或連接埠。	重大	中止傳輸並封鎖目的端；隔離來源主機並保全資料存取與網路紀錄。

4.1 評分邏輯

每關滿分 **100 分**，由固定答案表計算，確保相同選擇得到相同分數。

項目	計分
找出兩項主要證據	每項 20 分，共 40 分
找出第三項關聯證據	10 分
風險等級	完全正確 20 分；相鄰等級 10 分；其餘 0 分
兩項處置	每項 15 分，共 30 分

使用者最多選三筆證據、兩項處置；選錯佔用名額，但不另行倒扣。總分達 **70 分**視為通關。結果頁須逐項指出得分與失分原因，解釋各證據如何串成事件時

間線，並說明「誤報忽視」為何適用或不適用。

5. 資料結構設計

5.1 統一 Log 紀錄

每筆解析後的 Log 使用同一組欄位。無資料的非必要欄位可為 null，並保留 raw 以便核對來源。

欄位	型別	說明
id	字串	單筆紀錄的唯一識別碼
timestamp	ISO 8601 字串或 null	事件時間；有時區時保留時區資訊
source_type	字串	auth、web、endpoint、network 或 unknown
event_type	字串	例如 login_failed、http_request、process_start、outbound_transfer
src_ip、dst_ip	字串或 null	來源與目的 IP
host、user	字串或 null	涉及的主機與帳號
action、status	字串或 null	事件動作及結果
details	物件	各資料來源特有欄位，如 URL、行程名稱、位元組數
raw	字串	未修改的原始紀錄文字

JSON Log 範例：

```
{
  "id": "ssh-027",
  "timestamp": "2026-10-10T09:14:32+08:00",
  "source_type": "auth",
  "event_type": "login_success",
```

"src_ip": "203.0.113.42",

"dst_ip": "10.10.4.12",

"host": "web-prod-02",

"user": "ops-admin",

"action": "ssh_login",

"status": "success",

"details": {

"method": "password",

"preceding_failures_5m": 27

},

"raw": "2026-10-10T09:14:32+08:00 web-prod-02 sshd: Accepted password for ops-admin from 203.0.113.42"

}

5.2 案例與答案資料

每個內建案例包含 case_id、標題、背景、Log 識別碼清單、三個標準證據 id、正確風險等級、兩項正確處置及提交後解析。評分依據使用穩定的紀錄 id，不依賴畫面排序或關鍵字是否剛好相同。

5.3 使用者狀態

使用者狀態包含目前模式、篩選條件、暫選證據、暫選處置、各關最高分，以及手動風險標記。上傳資料與其原始內容不持久保存；重新載入頁面後需再次提供。

6. 驗收條件

1. 將單一 index.html 複製到無網路環境並直接開啟，四個案例、搜尋、篩選、圖表及評分均可使用。
2. 四個案例各有正常與異常紀錄，能透過時間線及至少三項證據完成判定。

3. 相同答案每次提交得到相同分數；錯誤選擇能取得具體解析。
4. 可載入支援格式的本機 Log；解析失敗的紀錄仍可查看原文。
5. 自訂 Log 可搜尋、篩選及手動標記，但不出現自動評分。
6. 重新整理後可恢復內建關卡最高分；上傳的原始 Log 不會被持久保存。